

Fiche de révision — C26 : Blockchain & Smart Contracts

Cours magistral court « *Blockchain et Smart Contracts* » — Bloc 4. Objectif : intégrer une blockchain (Ethereum, Hyperledger Fabric, registre managé) dans un SI pour renforcer **traçabilité, sécurité et intégrité**. (C26 évaluée en quiz.)

1. Pourquoi la blockchain dans un module Cloud ?

Le cloud sait **déployer, stocker, authentifier, superviser**. La blockchain répond à **un autre problème** : *comment prouver qu'une information n'a pas été modifiée et qu'un événement a bien eu lieu ?*

Problèmes de **confiance** typiques : un contrat a-t-il été modifié après validation ? une transaction est-elle à la bonne date ? un produit a-t-il suivi toutes les étapes logistiques ? un diplôme est-il authentique ? un journal d'audit peut-il être altéré par un admin ?

Idée clé. Les bases classiques reposent souvent sur une **autorité centrale** : si elle est compromise ou si un admin modifie les données, la **preuve devient discutable**. La blockchain est pertinente quand le besoin n'est pas seulement de **stocker** une donnée, mais de disposer d'une **preuve partagée, horodatée, vérifiable et difficile à falsifier**.

Cas entreprise. Plusieurs partenaires d'une chaîne logistique ne se font pas mutuellement confiance pour tenir « le » registre. Une blockchain partagée leur donne un **historique commun** que personne ne peut modifier seul.

2. Définition & composants

Une **blockchain** = registre numérique où les **transactions** sont regroupées en **blocs**, chaque bloc lié au précédent par un mécanisme **cryptographique** → historique difficile à modifier sans détection.

Composant	Rôle
Transaction	Opération enregistrée (transfert, validation, création d'actif, changement de statut)
Bloc	Ensemble de transactions validées ajoutées au registre
Hash	Empreinte cryptographique qui identifie un contenu et détecte toute modification
Nœud	Machine du réseau conservant une copie (totale/partielle) du registre
Consensus	Mécanisme d'accord des participants sur l'état valide du registre
Smart contract	Programme on-chain appliquant automatiquement des règles métier
Clé privée	Secret qui signe les transactions ; sa compromission = perte de contrôle

Immuabilité = append-only. Ça ne veut **pas** dire « rien n'est modifiable » : on **ajoute** des transactions, on ne réécrit pas silencieusement l'historique. Une opération incorrecte se corrige en **ajoutant une transaction de correction** → piste d'audit robuste.

Cas entreprise. Plutôt que de supprimer une écriture comptable erronée (et perdre la trace), on ajoute une écriture de correction : l'historique complet reste vérifiable pour l'auditeur.

3. Publique / privée / permissionnée

La distinction clé pour un architecte = la **gouvernance du réseau**.

Type	Principe	Cas d'usage
Publique	Tout le monde peut lire/participer (selon le protocole)	dApps, tokens, finance décentralisée, preuve publique
Privée	Réseau contrôlé par une seule organisation	Audit interne, registre d'entreprise
Permissionnée	Seuls des acteurs identifiés/autorisés participent	Consortium, supply chain, banque, assurance, industrie

⚠ Pour une entreprise, une blockchain **publique n'est pas toujours le bon choix** (confidentialité, coût, performance, conformité) → souvent **permissionnée** ou **registre managé**.

4. Ethereum vs Hyperledger Fabric vs registre managé

Critère	Ethereum	Hyperledger Fabric	Registre managé (ex. Azure Confidential Ledger)
Gouvernance	Publique (ou EVM privé)	Permissionnée, consortium	Gérée par un fournisseur cloud
Confidentialité	Faible par défaut (réseau public)	Plus forte (participants identifiés)	Forte selon le service
Smart contracts	Oui, souvent Solidity	Oui, chaincode	Variable
Usage type	Preuve publique, dApps, tokens	Supply chain, finance, industrie	Audit, intégrité, journal inviolable
Complexité	Moyenne à élevée	Élevée	Plus faible

- **Ethereum** : transparence, écosystème dev, standardisation ; **limites entreprise** = coût des transactions, confidentialité, gouvernance publique.
- **Hyperledger Fabric** : identités des participants, **canaux**, **chaincode**, registre partagé entre acteurs autorisés, gouvernance contrôlée.
- **Azure Confidential Ledger** : registre **append-only** résistant à la falsification → idéal quand on veut juste une **preuve d'intégrité** sans monter un réseau blockchain complet.

Cas entreprise. Une banque et ses partenaires (acteurs connus, données sensibles) → **Fabric**. Une DSI qui veut juste rendre un **journal d'audit inviolable** sans gérer un réseau → **registre managé**. Une preuve publiquement vérifiable par n'importe qui → **Ethereum**.

5. Smart contract : rôle & cycle de vie

Logique métier **exécutable on-chain** : créer un actif, changer son propriétaire, **vérifier une condition**, **refuser une transaction non conforme**, **enregistrer un événement horodaté**.

Cycle de vie : 1) analyser le processus à tracer → 2) choisir données **on/off-chain** → 3) rédiger les règles → 4) **tests unitaires + tests de sécurité** → 5) déploiement sur **réseau de test** → 6) revue fonctionnelle/technique → 7) production → 8) supervision/audit/évolutions.

À retenir. Le smart contract **ne remplace pas toute l'application** : il porte **seulement** les règles qui doivent être **partagées, vérifiables et difficiles à falsifier**.

Cas entreprise. Pour une location de matériel entre partenaires, le smart contract n'embarque pas l'UI ni la facturation complète — juste la règle « le statut ne peut passer à *loué* que si l'appelant est autorisé et que l'actif est *disponible* », horodatée.

6. Architecture d'intégration dans un SI

La blockchain s'utilise **rarement seule** : elle se combine avec app, API, bases et monitoring.

Couche	Rôle
Application métier	UI : saisie, consultation, validation
API / Backend	Contrôle les droits, orchestre, appelle la blockchain
Smart contract	Applique les règles de traçabilité, enregistre les événements critiques
Stockage off-chain	Documents volumineux, données personnelles, fichiers
Blockchain / Ledger	Preuves, empreintes, événements, transactions
Monitoring / Audit	Surveille transactions, erreurs, coûts, sécurité

Pourquoi off-chain ? On n'inscrit on-chain que l'essentiel : **empreinte** d'un document, **identifiant** de transaction, **statut**, **événement horodaté**, **lien** vers un stockage sécurisé. Les documents volumineux et les **données personnelles** restent dans des bases/stockages classiques avec contrôle d'accès.

Cas entreprise. Un PDF de contrat (10 Mo, données personnelles) reste dans un Blob privé chiffré ; seule son **empreinte SHA-256** + la date sont ancrées → on prouve l'intégrité sans exposer le document ni violer le RGPD.

7. Cas d'usage SI

- **Traçabilité logistique** : chaque acteur ajoute un événement (fabrication → contrôle → expédition → réception) → historique **partagé entre partenaires**.
- **Certification de documents/diplômes** : le PDF reste off-chain, son **empreinte** est inscrite → toute modification devient **détectable**.
- **Journal d'audit inviolable** : événements sensibles (changement de droits, validation de paiement, signature) dans un registre **append-only**.

8. Sécurité, intégrité & gouvernance

Ce que la blockchain améliore : **Intégrité** (modifs non autorisées détectables) · **Traçabilité** (événements horodatés) · **Non-répudiation** (transaction signée rattachée à une identité/clé) · **Auditabilité** (preuves vérifiables).

⚠ **Ce qu'elle ne résout PAS seule** : la **véracité des données à l'entrée** (*garbage in, garbage out*) — une info fausse mais validée sera conservée comme « preuve fiable d'une info fausse ». → garder **contrôles métier, processus de validation, gouvernance des identités**.

Risques principaux → **mesures** :

Risque	Mesure de réduction
Clé privée compromise	Coffre de secrets (Key Vault), rotation, MFA, séparation des rôles
Smart contract vulnérable	Tests, audit de code , revue externe, patterns sécurisés
Données personnelles on-chain	Off-chain + inscrire seulement l'empreinte (conformité, droit à l'effacement)
Mauvais choix de plateforme	Étude d'architecture + critères de choix explicites
Absence de gouvernance	Comité de gouvernance, règles de validation, gestion des versions

9. Comment choisir une solution blockchain ? (les 7 questions)

1. Les acteurs qui **écrivent** dans le registre sont-ils **connus** ?
2. Preuve **publique** ou seulement **partagée entre partenaires** ?
3. Les données sont-elles **confidentielles / personnelles** ?
4. Le **volume** de transactions est-il élevé ?
5. Le **coût** par transaction est-il acceptable ?
6. Le smart contract doit-il être **modifiable** ou strictement **immuable** ?
7. **Qui exploite** le réseau et **qui gère** les identités ?

Règle de décision. Acteurs connus + confidentialité importante → **permissionnée (Fabric)** ou **registre managé**. Preuve publique largement vérifiable → **Ethereum**.

Les réflexes à retenir pour C26

1. Blockchain = **preuve partagée, horodatée, infalsifiable** entre **plusieurs acteurs** sans autorité unique.
2. **Append-only** ≠ **immuable** au sens « rien ne bouge » : on corrige en **ajoutant**.
3. **Hash** = détection d'altération ; **clé privée** = signature (à protéger).
4. **Publique (Ethereum/Solidity)** vs **permissionnée (Fabric/chaincode)** vs **registre managé**.
5. **On-chain** = **empreinte/preuve** ; **off-chain** = **documents & données personnelles** (RGPD).
6. Elle **n'assure pas la véracité de l'entrée** (*garbage in*) ni ne remplace le SI.
7. Pour valider : **expliquer le besoin** → **choisir la plateforme** → **décrire le smart contract** → **justifier** (traçabilité/sécurité/intégrité).

Glossaire express

Terme	Définition
Blockchain	Registre distribué structuré en blocs liés cryptographiquement
Smart contract	Programme on-chain exécutant des règles métier
Chaincode	Nom du smart contract chez Hyperledger Fabric
Hash	Empreinte d'une donnée, détecte les modifications
Consensus	Mécanisme d'accord entre participants
On-chain / Off-chain	Stocké dans la blockchain / hors blockchain
Permissioned	Blockchain à participants identifiés et autorisés
Ledger	Registre contenant l'historique des transactions
Non-répudiation	Impossibilité de nier une transaction signée
Append-only	On ajoute, on ne réécrit pas l'historique



Un **quiz d'entraînement** complet (QCM + vrai/faux + questions courtes + mini-cas, avec corrigé) est disponible : docs/cours/blockchain/Quiz_C26_Blockchain.pdf.